

Securing Your Accounts: 2FA, Passkeys, and Security Tokens

CUCUG
Quentin Barnes
January 15, 2026



'Tis a Balance

- Security is a balance between
 - Authenticating only authorized users
 - Usability headaches and annoying those users
- Logins with passwords used to be adequate
 - Even then, **password hygiene** was still necessary

Password Weaknesses

- Can be:
 - Reused
 - Guessed or cracked
 - Spoofed or phished
 - Lost or forgotten
- Password managers can help with all of these

Addressing Shortcomings

- 2FA/MFA (2/Multi-factor authentication)
- Passkeys
- Software tokens (TOTP authenticator apps)
- Hardware security tokens

Multi-factor Authentication

- Uses two or more “factors”:
 - Something you know
 - Password, PIN, security question
 - Something you have
 - Phone, software/hardware token, email, smart card
 - Something you are
 - Fingerprint, face, iris, or retina

Less Common MFAs

- Can sometimes include:
 - Somewhere you are
 - Physical location (GPS), IP address
 - Something you do
 - Keystroke or mouse movements, gait

Passkeys

- “Passkey” is short for “WebAuthn credential”
- A cryptographic key stored on client’s system
 - Generated during negotiation with server’s system
- Acts in place of login/password
- Two types of passkeys
 - Synced (e.g. password manager)
 - Device-bound (e.g. hw token, Face ID, Windows Hello)

Passkey Advantages

- Each passkey is unique
 - Can only be used for logging in with the site that generated it
 - Can't be reused
 - Can't be guessed or cracked
 - Can't be spoofed or phished
- Considered MFA
 - Requires both unlocking and having the passkey's storage device
- Can have multiple passkeys per site and login

Passkey Disadvantages

- Not all web sites support passkeys
 - Passkeys first rolled out in 2022
 - Many sites use both passwords and passkeys for now
- Requires storage device
 - Browser, password manager, or hardware token
- MFA aspect can be defeated if no authentication required for storage device

TOTP Authentication

- Time-based One Time Passwords (TOTP)
 - Generates timed-limited passwords
 - Often 6-8 characters long
 - Sequences time out, often after 20-30 seconds
- HMAC-based OTP (HOTP) generate single use passwords

TOTP Authentication (cont.)

- **TOTP Apps** initialized with authenticator keys
 - Authenticator keys as alphanumeric strings or QR codes
 - **2FAS**, **Authy**, **Bitwarden**, **Google Authenticator**, etc.
 - Don't just pick a random TOTP app out of an app store!
- *Don't* use the same app for storing both passwords and authenticator keys unless you have enabled its MFA
 - Otherwise, you lose MFA security

Hardware Security Tokens

- Tokens are teeny computers. They can:
 - Store passwords, cryptographic keys, digital signatures
 - Run various cryptographic algorithms
- Portable ones may have
 - USB/USB-C, Bluetooth, and/or NFC interfaces
 - Small, tamper resistant packaging
 - A screen, keypad, or bio sensors

Hardware Security Tokens (cont.)

- Various manufacturers
 - Yubico, Thetis, Google, Nitrokey, Feitian, SoloKeys
- Authenticate with PIN or Bio sensor
- Want at least FIDO2 support
- Portable ones cost \$18-\$125
- You may already have one! (fTPM)

Recommendations

- Use a good [password manager](#)
 - Avoid web browser's native password manager
 - Recommend [Bitwarden](#); others okay, but consider limits, \$\$\$
 - Excellent free features, open source, multi-platform
 - Good free tier, premium tier just \$10/yr
 - Transition your login accounts into it
 - Replace your weak, exposed, and reused passwords
 - Enable Passkeys/MFA with your password manager

Recommendations (2)

- Check each site for supporting passkeys [\[1\]](#)
 - May want to create more than one passkey
 - Delete your password when comfortable (optional)
- Sites without Passkeys, use their MFA [\[2\]](#)
 - But caution with phone numbers! (MFA vs. recovery)
 - Set up software or hardware tokens [\[3\]](#)
- If no passkeys and no MFA, consider alternate sites
 - Especially for financial or otherwise important security needs

Recommendations (3)

- Secure your password manager with MFA
 - Have backups of MFA keys
 - Consider 2+ backups and kept apart, off-site
 - Safe deposit box (as little as \$20/yr), friend's house

Questions?

Demos?